

SEMINÁRIO

Autenticação & Autorização

Como os sistemas descobrem quem é o usuário e decidem o que ele pode fazer.

Nome do Apresentador 1

Parte 1 — Autenticação

Nome do Apresentador 2

Parte 2 — Autorização

Nome do Apresentador 3

Parte 3 — Segurança na prática



O que vamos ver

01

Autenticação

Fatores, MFA e métodos modernos de provar identidade.

APRESENTADOR 1

02

Autorização

RBAC, ABAC e ACL, OAuth 2.0, OpenID Connect e JWT.

APRESENTADOR 2

03

Segurança na prática

Falhas do OWASP, checklist de boas práticas e tendências.

APRESENTADOR 3

01

Autenticação

Quem é você? Como um sistema verifica a identidade de quem está do outro lado.

- Apresentador 1 — Nome do Apresentador 1

O que é autenticação

É o processo de **comprovar que uma identidade declarada é verdadeira**, antes de o sistema conceder qualquer acesso.

Declarar quem você é não basta, a prova apresentada (senha, código, biometria) é que realmente autentica o usuário.

- 1 Identificação**
O usuário informa quem diz ser
- 2 Verificação**
O sistema confere a prova apresentada
- 3 Sessão**
A identidade passa a valer por tempo limitado

Fatores de autenticação

Toda prova de identidade cai em uma destas três categorias.

CONHECIMENTO

Algo que você sabe

Senha, PIN, resposta secreta.

Pode ser descoberto, reutilizado ou vazado.

POSSE

Algo que você tem

Celular com app autenticador, chave FIDO, cartão.

Exige acesso físico ao dispositivo.

INERÊNCIA

Algo que você é

Impressão digital, face, voz.

Não se troca depois de comprometido.

Autenticação multifator

MFA é combinar fatores de **categorias diferentes**.
Duas senhas não são dois fatores.

O atacante que descobre a senha ainda precisa do dispositivo do usuário — e é isso que derruba ataques em massa de credenciais vazadas.

FORTE

Senha + chave FIDO ou passkey

Resistente a phishing por vínculo ao domínio

BOM

Senha + código TOTP do app

Código local, válido por 30 segundos

FRÁGIL

Senha + código por SMS

Vulnerável a SIM swap e interceptação

Métodos em uso hoje

Senha com hash

Armazenada como hash lento e com salt — bcrypt, scrypt ou Argon2, nunca em texto puro.

`argon2id$v=19$m=65536`

TOTP

Código de 6 dígitos gerado do segredo compartilhado mais o horário atual.

`HMAC(segredo, tempo/30)`

Biometria

A comparação acontece no dispositivo; o servidor recebe só o resultado, não a digital.

`match local → assinatura`

Passkeys (WebAuthn)

Par de chaves por site: a privada fica no dispositivo, o servidor guarda só a pública.

`desafio → assinatura → OK`

02

Autorização

O que você pode fazer? Modelos de permissão, delegação de acesso e tokens.

- Apresentador 2 — Nome do Apresentador 2

Autenticação não é autorização

CRITÉRIO	Autenticação	Autorização
Pergunta	Quem é você?	O que você pode fazer?
Quando ocorre	Uma vez, na entrada	A cada requisição
Evidência	Senha, código, biometria	Papéis, atributos, políticas
Falha responde	401 Unauthorized	403 Forbidden

Modelos de controle de acesso

RBAC

POR PAPEL

Permissões ficam no papel; o usuário recebe papéis.

`admin → editar tudo leitor → apenas ver`

ABAC

POR ATRIBUTO

Regras avaliam atributos do usuário, do recurso e do contexto.

`setor = financeiro e horário comercial`

ACL

POR RECURSO

Cada recurso carrega a lista de quem pode o quê.

`doc-42: ana=rw doc-42: joão=r`

Fluxo OAuth 2.0 e OpenID Connect

OAuth 2.0 delega acesso; o OpenID Connect acrescenta a camada de identidade.



ACCESS TOKEN

autoriza chamadas à API

ID TOKEN

informa quem é o usuário autenticado

Anatomia de um JWT

```
eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiIxMDIiLCJyb2x1IjoieYWRtaW4ifQ.Kx7f2Qa9nR1sYb0cLmT4wZp
```

Header

Algoritmo e tipo do token.

`alg, typ, kid`

Payload

Claims: quem é, o que pode, até quando vale.

`sub, role, exp, iss`

Signature

Garante integridade — só o emissor consegue produzi-la.

HS256 ou RS256

O payload é apenas codificado em Base64, não criptografado: qualquer um pode ler o conteúdo.

03

Segurança na prática

Onde esses controles falham no mundo real e o que já é padrão para evitar isso.

- Apresentador 3 — Nome do Apresentador 3

Falhas mais comuns segundo o OWASP

A01

Quebra de controle de acesso

Trocar o ID na URL e ver o dado de outro usuário (IDOR)

Verificar permissão só na interface, não na API

Endpoint administrativo acessível sem checagem

A07

Falhas de identificação e autenticação

Credenciais vazadas reutilizadas em massa

Sem limite de tentativas de login

Sessão que nunca expira ou token sem revogação

Checklist de boas práticas

- ✓ Negar por padrão e liberar explicitamente
- ✓ Hash lento com salt para senhas — Argon2 ou bcrypt
- ✓ Tokens de vida curta, com refresh e revogação
- ✓ Mensagens de erro genéricas, sem revelar se o usuário existe
- ✓ Validar autorização no servidor, a cada requisição
- ✓ MFA obrigatório para contas privilegiadas
- ✓ Rate limit e bloqueio progressivo no login
- ✓ Registrar em log todo acesso negado e toda troca de permissão

Para onde a área caminha

TENDÊNCIA 01

Zero Trust

Nenhuma rede é confiável por estar dentro do perímetro: identidade, dispositivo e contexto são verificados em cada acesso.

TENDÊNCIA 02

Passwordless

Passkeys e chaves FIDO2 substituem a senha por criptografia de chave pública — sem segredo para vazar ou phishar.

Recapitulando o modelo

ETAPA 01

Autenticação

Confirma quem está acessando.



ETAPA 02

Autorização

Define o que essa identidade pode fazer.



ETAPA 03

Auditoria

Registra o que foi feito e por quem.

As três etapas se sustentam juntas: autenticar sem autorizar libera demais, autorizar sem auditar deixa o incidente invisível.

Perguntas?

Autenticação responde quem é você.

Autorização responde o que você pode fazer.

Auditoria conta o que aconteceu.